

PROGRAMME DE FORMATION · VERSION 3 · 2026-09-13

AI Security : sécuriser les usages de l'IA generative

Évaluez la sécurité d'une application d'IA générative sur un laboratoire autorisé. Vous modélisez les menaces, limitez les accès et testez les protections contre détournements, divulgations et actions excessives.

2 jours · 14 heures

Avancé · Hybride

1 990 € HT

Tarif indicatif, dates, disponibilité et modalités contractuelles à confirmer avec le centre.

À qui s'adresse cette formation ?

RSSI, responsables securite, DSI, data officers, responsables innovation et conformité.

Prérequis

Connaissance generale des environnements numeriques et des enjeux de donnees.

Objectifs pédagogiques

- Identifier les principaux risques securite lies a l'IA generative
- Mettre en place des garde-fous adaptes aux usages de l'entreprise
- Coordonner les enjeux entre metier, IT, data et conformite

Le cas fil rouge

Évaluer la sécurité d'un assistant documentaire d'entreprise et définir les protections vérifiables avant son ouverture.

Préparation

Notions de sécurité applicative et architecture IA ; environnement fictif, documents synthétiques et tests exclusivement autorisés.

Progression détaillée

Répartition pédagogique proposée sur une base de 7 heures par jour, pauses exclues. À ajuster avec le formateur au positionnement initial. Les approfondissements « Pour aller plus loin » sont sélectionnés par le formateur selon le positionnement et le temps disponible ; ils ne constituent pas des heures supplémentaires garanties.

Jour 1 · 7 heures

1. Modéliser les menaces de l'application

210 minutes · apports, exercice et retour

- Cartographier utilisateurs, corpus, modèle, outils et flux de données.
- Identifier frontières de confiance et actifs sensibles.
- Examiner injection de prompt, divulgation, abus d'outils et sorties non fiables.

- Cartographier entrées, corpus, outils, identités et frontières de confiance d'une application IA.

NOTIONS ET MÉTHODES EN DÉTAIL

- Dessiner frontières de confiance entre utilisateur, documents, modèle, outils et données.
- Distinguer injection directe, instruction dans un document et abus d'un outil connecté.
- Classer conséquences : information trompeuse, fuite, coût excessif et action non autorisée.

Atelier prévu

Construire un modèle de menaces de l'assistant RH et prioriser les scénarios selon exposition et impact.

Livrable attendu

Modèle de menaces et chemins d'abus.

Vérification en atelier

La cartographie relie chaque menace à une surface et à un impact précis.

Pour aller plus loin · selon positionnement et temps disponible

Examiner injection indirecte, exfiltration et abus d'outils sur un scénario défensif isolé.

2. Protéger les données et les outils

210 minutes · apports, exercice et retour

- Contrôler les autorisations avant la recherche documentaire.
- Limiter privilèges, paramètres et effets des outils.
- Protéger secrets, traces et données transmises au fournisseur.
- Appliquer permissions minimales, validation des arguments, cloisonnement et contrôle des sorties.

NOTIONS ET MÉTHODES EN DÉTAIL

- Appliquer autorisations côté serveur et comptes de service à privilèges limités.
- Séparer secrets et contexte du modèle ; filtrer les sorties sensibles avant restitution.
- Limiter types d'action, arguments, destinations réseau et volume des fichiers traités.

Atelier prévu

Définir une matrice d'accès et tester sur données fictives qu'un document réservé ne ressort pas pour un profil non habilité.

Livrable attendu

Architecture de protections et politique d'outils.

Vérification en atelier

Une proposition du modèle ne peut pas élargir les droits accordés à l'application.

Pour aller plus loin · selon positionnement et temps disponible

Limiter une action sensible même lorsque le modèle produit une instruction erronée.

Jour 2 · 7 heures

3. Évaluer les protections

210 minutes · apports, exercice et retour

- Préparer tests d'instructions hostiles dans des sources non fiables.

- Vérifier validation des sorties, quotas et limites d'exécution.
- Distinguer filtre textuel et contrôle applicatif effectif.
- Construire cas adversariaux, critères de succès et tests de non-régression ; mesurer aussi les faux refus.

NOTIONS ET MÉTHODES EN DÉTAIL

- Construire un jeu de tests d'abus sur données synthétiques et environnement autorisé.
- Tester document hostile, demande de secret, entrée longue et refus contourné par reformulation.
- Mesurer protections et faux refus sans considérer un filtre lexical comme une garantie complète.

Atelier prévu

Exécuter une recette de laboratoire avec tentatives de dépassement du périmètre, puis consigner preuve, résultat et risque résiduel.

Livrable attendu

Rapport de tests défensifs et limites résiduelles.

Vérification en atelier

Le rapport reproduit les cas et indique les limites des contrôles testés.

Pour aller plus loin · selon positionnement et temps disponible

Évaluer une protection sur attaques reformulées et documents non fiables.

4. Organiser surveillance et réponse

210 minutes · apports, exercice et retour

- Définir alertes de comportement et traces utiles.
- Prévoir suspension, repli et revue après incident.
- Répartir responsabilités métier, sécurité, data et fournisseur.
- Définir logs proportionnés, signaux d'abus, arrêt d'urgence et investigation.

NOTIONS ET MÉTHODES EN DÉTAIL

- Définir traces expurgées, seuils de débit et signaux de comportement anormal.
- Préparer suspension d'outil, rotation d'un secret exposé et reprise du service.
- Organiser réévaluation après changement de modèle, corpus ou connecteur.

Atelier prévu

Livrer un plan de sécurisation avec tests de non-régression et procédure de traitement d'une divulgation simulée.

Livrable attendu

Plan de surveillance et procédure d'incident.

Vérification en atelier

Le scénario d'incident identifie qui peut arrêter l'action et vérifier la correction.

Pour aller plus loin · selon positionnement et temps disponible

Simuler une fuite suspectée sans copier de données réelles dans l'exercice.

Évaluation finale

Mise en situation individuelle et restitution commentée, incluses dans la dernière séquence. Durée indicative : 60 minutes.

- Les contrôles d'accès sont indépendants du modèle.
- Chaque menace prioritaire a un test et une mesure.
- Les limites des protections et les actions d'incident sont explicites.

Méthodes et ressources

Apports illustrés, exercices progressifs, ateliers sur un cas fil rouge et retour argumenté sur les productions. Les ateliers et l'évaluation font partie des heures indiquées.

Les ateliers décrivent les travaux prévus. Leurs fichiers, corrigés et évaluations en ligne sont à préparer, sauf ressources explicitement disponibles dans le module pilote.

Accès, accompagnement et contact

Pour obtenir plus de détails ou le programme détaillé validé, contactez le centre : 09 54 70 23 80 — contact@beyondexpertise.eu.

Positionnement et vérification des prérequis avant inscription. Délais, calendrier et aménagements à convenir avec le centre. Pour un besoin d'accessibilité, décrivez le besoin pratique sans diagnostic médical.

Programme enrichi proposé, à valider par le formateur avant animation. Les approfondissements sont adaptés au niveau et au temps disponible. Aucune certification professionnelle ni prise en charge CPF ou OPCO n'est garantie. Démarche Qualiopi en cours ; certification non acquise.

Références pour approfondir

- OWASP · sécurité des applications LLM
- CNIL · intelligence artificielle et données personnelles